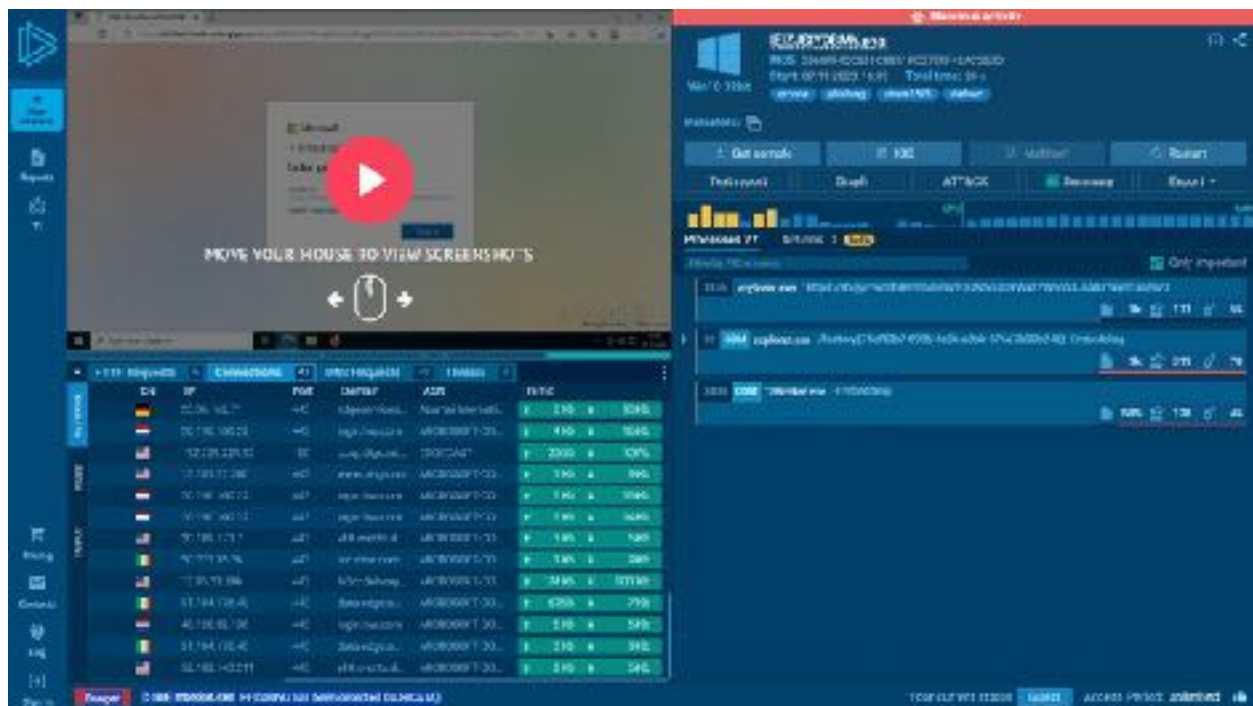


LA-3

22BCI0052

Nori Karthikey

1.



1. Initial Assessment

a. Indicators of malicious activity:

- The file is flagged as malicious by ANY.RUN and matched phishing indicators.

- Suricata detection identified phishing behaviour during execution.
- The file triggered connections to suspicious domains particularly rb.gy and tek1z9bq4r5ah6s.swnbdgfgzy.ru.
- The analysis logs showed social engineering and phishing attempts through browser redirects.

b. File name and extension meaning:

The file name IEIZJSIYDBMY.png and its .png extension suggest it is a harmless image file. However, upon analysis, the image has a QR code that redirects to a phishing link when scanned or opened. This shows that the attacker disguised a phishing payload inside an image file to trick users into opening malicious links.

2. Process Behaviour Analysis

a. Behaviour of msedge.exe:

- The process msedge.exe (Microsoft Edge) was launched several times during execution.
- Each launch accessed different URLs, primarily the shortened domain rb.gy, which redirected to a phishing site.

- The repeated launches indicate automatic or scripted redirection, likely intended to display fake login pages or download additional content.
- This activity shows that the PNG file indirectly caused browser exploitation through malicious link execution.

b. Indicators of Compromise (IOCs) linked to msedge.exe are:

- rb.gy – URL shortening service used for phishing redirection.
- tek1z9bq4r5ah6s.swnbdgfgzy.ru – Suspicious Russian domain involved in phishing activity.

Threat details
Here are the details of the threat

Main Stream data T.S The data provided by Suricata IDS

Possible Social Engineering Attenuated

PHISHING [ANY.RUN] Phishing domain chain detected (DadSec)

Src / Dst	192.168.100.64:4444 → 104.17.2.184:443 /T
Timeshift	2640 ms
SID	60C1093: rev. 3:
Transport	TCP
App Protocol	TL6
Src IP	192.168.100.64
Dst IP	104.17.2.184
Src Port	4444
Dst Port	443
To ICMP Packet	4
To ICMP Packet	4
Total Bytes	3059

3. Registry Modifications

a. Observed modifications:

No major registry modifications are recorded in this specific execution. If present, such changes would normally suggest attempts to maintain persistence or alter system/browser settings.

b. Tracking malware through registry changes:

Even though not observed here, registry modifications can help trace malware activity by:

- Identifying added startup entries that cause malware to relaunch automatically.
- Tracking modified browser configurations that redirect users to phishing sites.

4. Network Analysis

a. HTTP request significance:

- Multiple HTTP GET requests are made to Microsoft update and security servers, which is normal background behaviour.
- However, suspicious requests to rb.gy and redirection to phishing domains were observed.

- The HTTP 200 OK responses confirm successful communication with the phishing server, meaning the malicious page was loaded properly.

b. Suspicious external connections:

Connections to the following suspicious IPs suggest communication with potentially malicious servers:

- 172.67.201.235
- 104.21.76.226

These addresses belong to servers used by the domain `swnbdgfgzy.ru`, which may host phishing content or act as a command-and-control (C2) infrastructure.

c. Significance of `rb.gy` domain:

The use of `rb.gy`, a URL shortening service, indicates that the attacker tried to hide the true destination of the phishing site. Shortened links make it difficult for users and security tools to detect malicious domains, increasing the success rate of phishing campaigns.

5. Malware Persistence and Impact

a. Dropped or modified files:

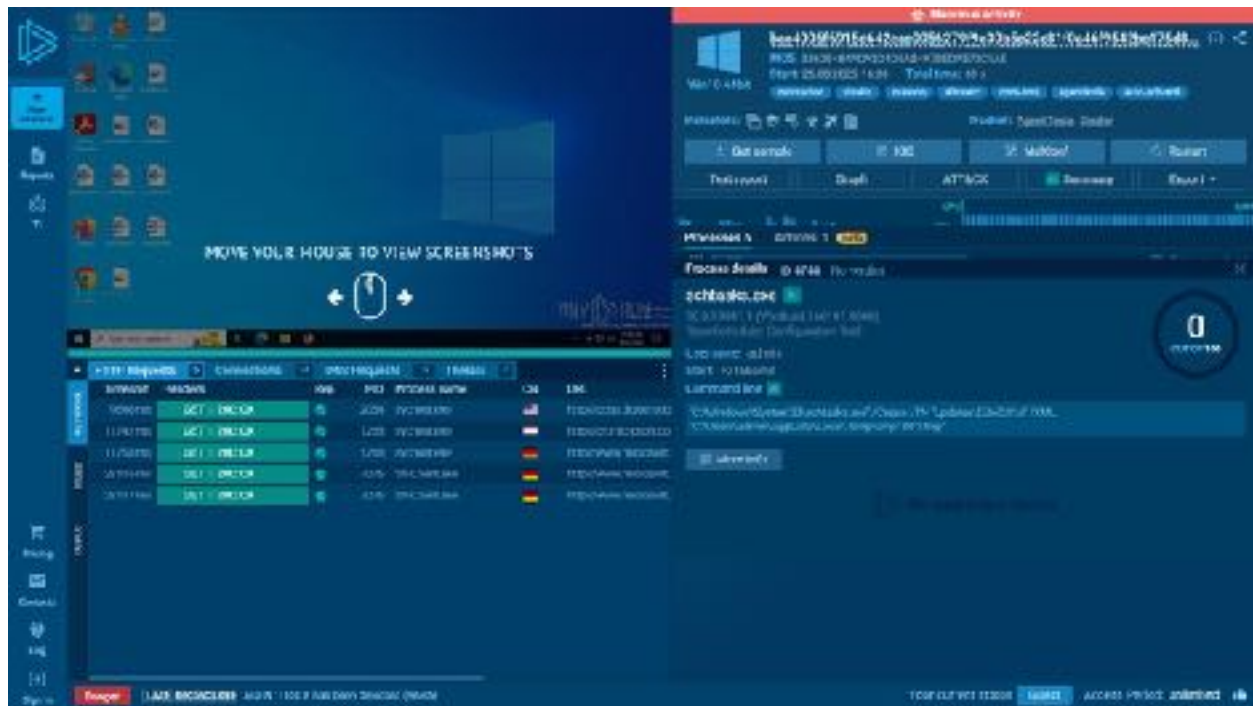
No permanent files or executables are dropped on the system. The activity was limited to browser-based phishing redirection and did not involve direct file modification.

b. Persistence methods:

In this sample, no persistence mechanisms are established. However, malware of this nature may attempt persistence in similar attacks through:

- Adding registry Run keys for automatic startup.
- Creating scheduled tasks to reopen phishing links.

II.



1) Identify the tactics and techniques based on MITRE ATT&CK

a. Tactics used by the malware:

The malware employs multiple tactics including initial access to gain entry into the system, persistence to ensure repeated execution after reboot, execution to run malicious code through legitimate processes, collection to steal credentials and other sensitive information, command and control to communicate with external servers, and evasion to avoid detection by security tools.

b. Techniques used to achieve these tactics:

- SMTP for Data Theft – using email protocols to transfer stolen data.
- External IP Discovery – querying api.ipify.org to gather network information for evasion.

2) Review the indicators of compromise (IoCs)



The screenshot displays a 'Threat details' window from a security tool, likely Suricata. The window has a dark blue header with the title 'Threat details' and a subtitle 'Here are the details of the threat'. Below the header, there are three tabs: 'Main', 'Stream data', and 'Suricata rule'. The 'Main' tab is selected. A yellow banner at the top of the main content area reads 'Device Relaying External IP Address Detected!'. Below this, the title 'ET INFO External IP Lookup api.ipify.org' is displayed. The main content area contains a table of network details:

MIME:	T1560 Gather Victim Network Information
Src / Dst:	192.168.100.4:49732 ⇄ 104.26.12.205:80
TimeShift:	28590ms
SID:	2001997;rev:6;
Transport:	TCP
App Protocol:	HTTP
Src IP:	192.168.100.4
Dst IP:	104.26.12.205
Src Port:	49732
Dst Port:	80
To Dst IP Packet:	3
To Src IP Packet:	4
Total Bytes:	440

Critical IoCs:

FilePath:C:\Users\admin\AppData\Local\Temp\tmp1D61.tmp

ScheduledTask: Updates\DZxZJCul

Process names:

RegSvcs.exe, schtasks.exe, svchost.exe, SIHClient.exe

External IP addresses and domains:

104.26.12.205, 172.67.74.152 (api.ipify.org)

50.116.95.71 (mail.horizongroup.com.bd)

40.126.31.3, 40.127.240.158 (settings-win.data.microsoft.com)

3) Examine malicious activity and system interaction

a. Evasion methods:

- Use of legitimate Windows processes to execute malicious actions, masking activity as normal system behaviour.
- Telemetry and update servers are used to blend malicious network traffic with normal Windows communications.

b. Potential impacts on system and network:

- Compromise of sensitive information including credentials.
- Persistent malware execution via scheduled tasks.

4) Correlation with MITRE ATT&CK framework

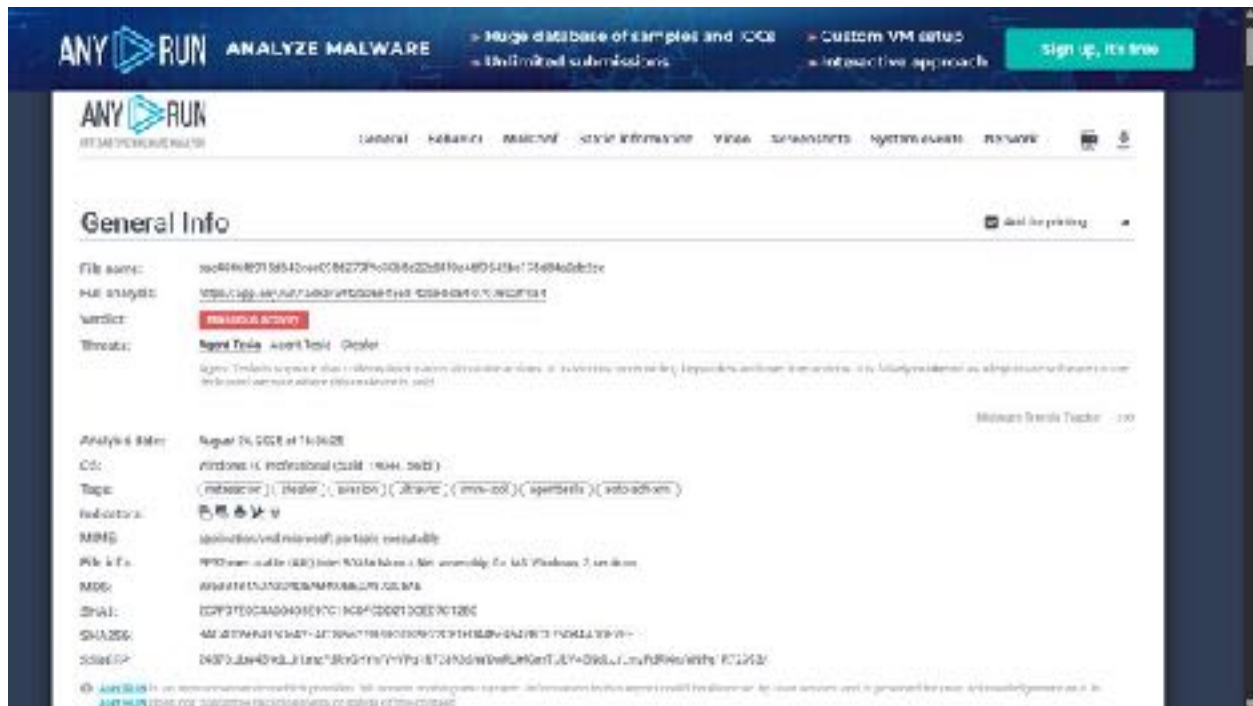
a. Events aligning with techniques:

- Scheduled Task creation – T1053
- Process execution via legitimate binaries – T1566.001, T1055
- External IP lookups – T1071.001
- SMTP activity for data transfer – T1041

b. Use of techniques for persistence or lateral movement:

Scheduled tasks and the abuse of legitimate system processes allow the malware to persist after reboot and evade detection, while collected credentials and network information can be leveraged to move laterally to other machines or servers within the network. C2 communications enable remote operators to execute additional payloads or commands, further extending the attacker's reach and impact.

III.



Primary Role of wscript.exe

The wscript.exe process serves as the main execution engine for the WSHRAT malware, responsible for running the malicious scripts that propagates the attack. It ensures that the malware's components are launched in the correct sequence and facilitates the overall execution flow of the infection.

Associated Malicious File

During the attack, wscript.exe executes the payload

[bac4006f6915d642eac0956279f9e30b5e22c81f0a46f9542bc175d84a0de2ee.exe]

located in C:\Users\admin\AppData\Local\Temp\.

This executable acts as the primary malware component responsible for system compromise, data collection, and communication with external servers.

Behaviour and Actions

wscript.exe coordinates multiple malicious activities through its execution of the payload. It triggers Task Scheduler entries via schtasks.exe to maintain persistence, ensuring the malware runs automatically after system reboots.

It launched RegSvcs.exe process, which is used to collect sensitive information, including credentials from web browsers, system configuration details, proxy settings, and Internet Explorer security settings. The malware also creates temporary files and directories in the user environment to support its operation.

System Modifications

The malware modifies several registry keys under

[HKEY_LOCAL_MACHINE\SOFTWARE\WOW6432Node\Microsoft\Tracing\]

to disable tracing and logging features. These modifications help evade detection by reducing the visibility of its actions and suppressing system-generated logs that could alert security tools or analysts.

Network Activities

wscript.exe, through the executed payload and supporting processes, facilitates communication with external servers. The malware performs external IP lookups using api.ipify.org and sends collected credentials via SMTP through mail.horizongroup.com.bd on port 587. These network connections allow the attackers to exfiltrate stolen data and maintain command-and-control capabilities.